MODULE 4 · LECTURE 21_Part1

CS 6530 Applied Cryptography

X.509 Certificates and Certificate Validation

Module 4 – Key Management, Certificates and PKI

How Do We Bind an Identity to a Public Key?

X.509 is the standard framework that defines public-key certificates and their use in certificate-based authentication.

X.509 CERTIFICATE



Identity

mail.google.com

Identity ↔ Public Key



Public Key

PK



Issuer's Digital Signature

The certificate carries the identity and public key; the issuer's digital signature authenticates the signed certificate information, including this binding.

? THINK LIKE AN ENGINEER

Does a valid CA signature alone mean that we should accept this identity–public key binding?

INSIGHT

The certificate asserts the binding; trust in that assertion still has to be established.

An X.509 certificate provides a signed identity–public key binding; validation determines whether we accept it.

BUILDING THE BINDING

What Information Must a Certificate Carry?

X.509 CERTIFICATE Identity ↔ Public Key

WHO? Subject / identity information	**WHICH KEY?** Public key
WHO VOUCHES? Issuer	**WHEN VALID?** Validity period
FOR WHAT? Usage / constraints	**HOW AUTHENTICATED?** Issuer's digital signature

Issued by a Certification Authority (CA), containing:

- version V - v1, v2, or v3
- serial number (SN) identifying certificate (unique for certificates issued by that CA)
- signature algorithm identifier (AI)
- issuer name (CA) – X.500 Distinguished Name (DN)
- period of validity TA (from - to dates)
- subject name (A) (name of owner) – X.500 DN
- subject public-key info A_p (algorithm, parameters, key)
- issuer unique identifier (v2+)
- subject unique identifier (v2+)
- extension fields (v3)
- signature (generated over the TBS certificate information (typically via its hash)
- notation CA<<A>> denotes certificate for A signed by CA

CA<<A>> = CA{V, SN, AI, CA, UCA, A, UA, Ap, TA}

? THINK LIKE AN ENGINEER

Can one certificate bind multiple identity names to the same public key?

INSIGHT

X.509 standardizes how this information is represented in a certificate.

A certificate tells us whose key, which key, who asserts it, when it is valid, and how it may be used.

CERTIFICATES IN THE REAL WORLD

Same Standard — Do All Certificates Look the Same?

GOOGLE MAIL	IIT MADRAS	AMAZON INDIA
Identity name **mail.google.com**	*Identity name* ***.iitm.ac.in**	*Identity name* **www.amazon.in**
Issuer **Google Trust Services WE2**	*Issuer* **Sectigo Public Server Authentication CA OV R36**	*Issuer* **Amazon RSA 2048 M01**
Public key **EC · 256 bits**	*Public key* **RSA · 2048 bits**	*Public key* **RSA · 2048 bits**
Validity **10 Aug 2026 → 2 Nov 2026**	*Also identifies* **iitm.ac.in**	*Also identifies* **Multiple DNS names**

Common: identity information · issuer · public key · validity · constraints · signature

Can differ: identities · issuers · key algorithms · validity · permitted uses

? THINK LIKE AN ENGINEER

How does X.509 represent one or more identity names inside a certificate?

INSIGHT

X.509 standardizes the certificate structure — not the identity, issuer, or public-key algorithm.

The same X.509 structure can bind different identities to public keys using different cryptographic algorithms.

X.509 CERTIFICATE STRUCTURE

How Does X.509 Represent the Binding?

X.509 v3 CERTIFICATE

tbsCertificate — "To Be Signed"

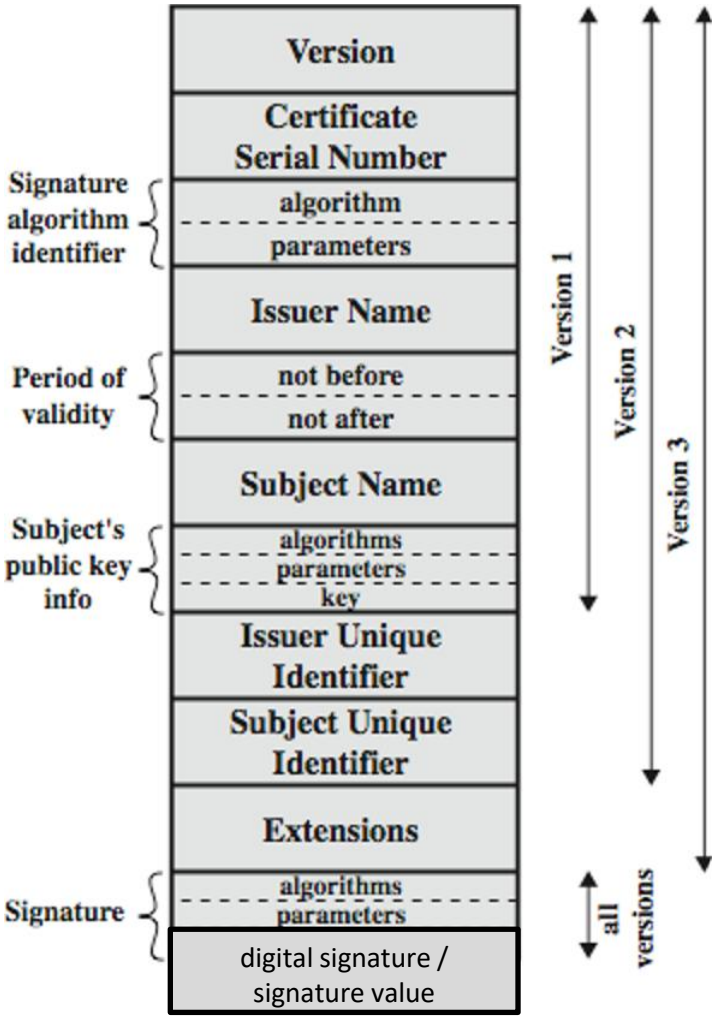
Version	Serial Number
Signature Algorithm ID	**Issuer**
Validity *Not Before / Not After*	**Subject**
Subject Public Key Info *Public-Key Algorithm, Public Key*	Extensions (v3)

Certificate Signature Algorithm

Algorithm used by the issuer to sign the certificate

Issuer's Digital Signature

Signature over tbsCertificate



X.509 Certificate

THINK LIKE AN ENGINEER

Which fields tell us "whose key?" and "who vouches for it?"

An X.509 certificate contains the identity–public-key assertion and the issuer's signature authenticating that assertion.

WHO IS CERTIFIED? WHO VOUCHES?

Subject vs Issuer — Two Different Identities

CA

ISSUER

Sectigo Public Server Authentication CA OV R36

issues + digitally signs

IIT MADRAS CERTIFICATE

Subject
***.iitm.ac.in**

Subject Public Key
RSA · 2048 bits

ISSUER

CA that issued and digitally signed the certificate

SUBJECT

Entity whose public key is being certified

Certificate contains → Subject's public key

Certificate signed using → Issuer's private key

? QUICK CHECK

Whose private key signed the IITM certificate?

A. IITM's B. Issuing CA's C. Browser's D. Root CA's

? THINK LIKE AN ENGINEER

Is the Subject field alone sufficient to determine all identities for which a certificate is valid?

Subject identifies who is certified; issuer identifies who signed the certificate assertion.

CERTIFICATE IDENTITY

Which Identity Names Does the Certificate Cover?

SUBJECT ALTERNATIVE NAME (SAN)
Certificate extension that carries identity names covered by the certificate — here, DNS names.

IIT MADRAS — Subject Common Name (CN) = *.iitm.ac.in

Which of these identity names are covered?

✓ covered	✓ covered	✓ covered
www.iitm.ac.in	courses.iitm.ac.in	iitm.ac.in

SAN: DNS:*.iitm.ac.in DNS:iitm.ac.in

***.iitm.ac.in** → covers one-label subdomains such as www.iitm.ac.in, courses.iitm.ac.in

iitm.ac.in → explicitly covers the base domain

GOOGLE MAIL

Subject CN: mail.google.com
SAN: mail.google.com, inbox.google.com
inbox.google.com covered? → Yes — it is in SAN

AMAZON INDIA

Subject CN: www.amazon.in
SAN: Multiple DNS names

Authenticated DNS identities are not determined from Subject CN alone.

? THINK LIKE AN ENGINEER

If the identity matches, may this certificate be used for any cryptographic purpose?

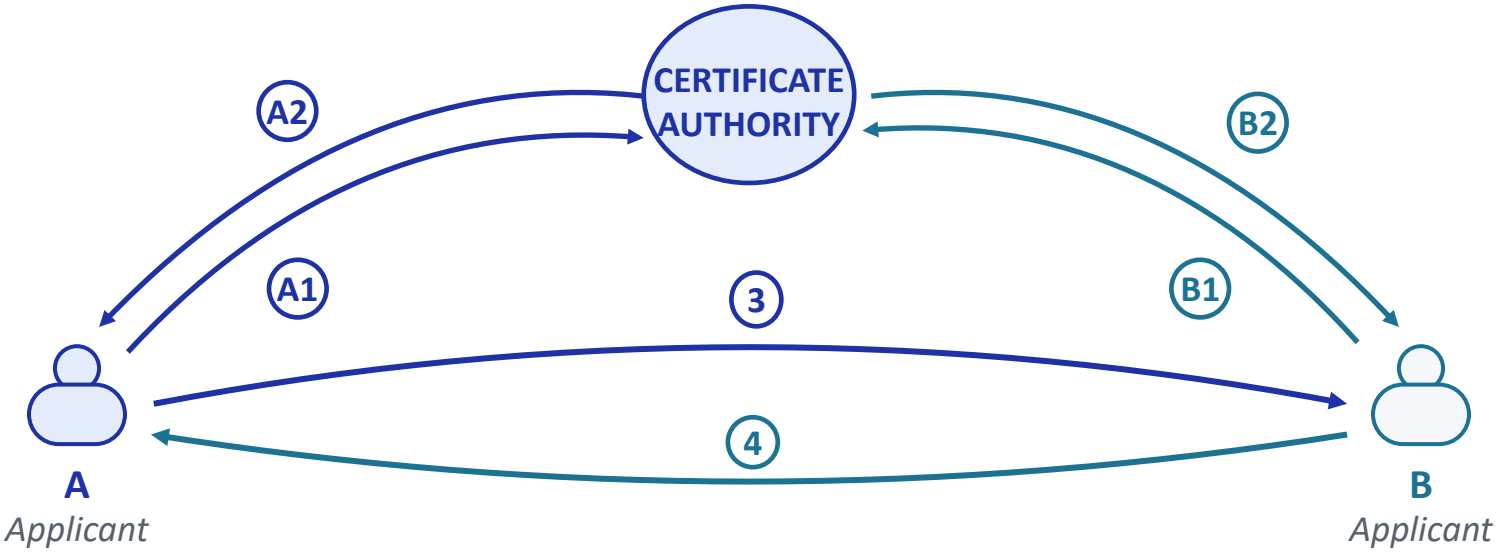
INSIGHT

One public key can be certified for multiple identity names.

For TLS server identity, validate the requested DNS name against the certificate's SAN—not merely its Subject CN.

CERTIFICATE ISSUANCE & USE

How Is a Certificate Created and Used?



A1 A→CA: request + PK_A
A2 CA→A: issues + signs **CA≪A≫**
3 A→B: presents **CA≪A≫** — B verifies, obtains trusted PK_A
4 B→A: presents **CA≪B≫** — A verifies, obtains trusted PK_B

B1 B→CA: request + PK_B
B2 CA→B: issues + signs **CA≪B≫**

Exchange need not be mutual, and certificates need not be secret.
Advantage: *verifiable later — no real-time CA contact needed.*

? THINK LIKE AN ENGINEER
What exactly does the CA digitally sign?

A CA issues signed identity–public-key bindings that entities can present to relying parties for validation.

CERTIFICATE CRYPTOGRAPHY

What Exactly Does the CA Sign?

CA CREATES THE CERTIFICATE

tbsCertificate

Serial · Issuer · Validity
Subject · SPKI · Extensions

↓

Hash

↓

Digital Signature
(sign with CA private key)

↓

signatureValue

SIGNED X.509 CERTIFICATE

X.509 CERTIFICATE

tbsCertificate
(incl. Subject Public Key)

signatureAlgorithm

✓ **signatureValue**

RELYING PARTY VERIFIES

tbsCertificate → Hash

signatureValue + CA public key → Verify

↓

Signature valid?

✓ **Accept** ✗ **Reject**

KEY CONCEPT: Protected: Identity · Public Key · Validity · Constraints

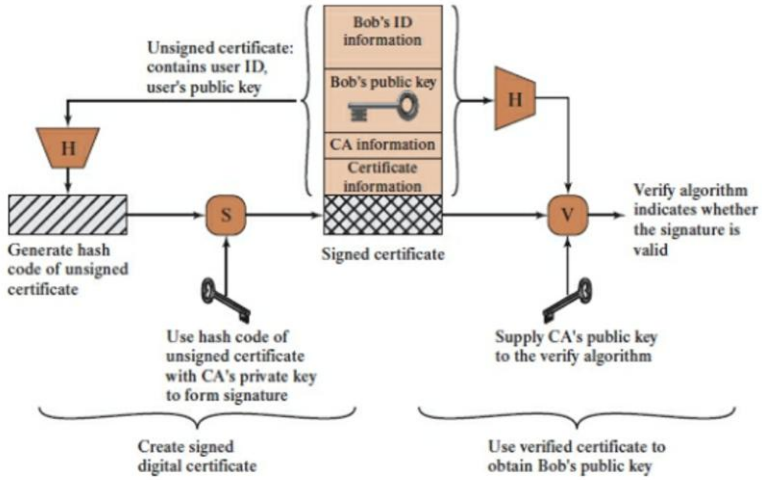
The CA signs the certificate information — not merely the subject's public key.

? THINK LIKE AN ENGINEER

The signature protects these fields — but may the certified key be accepted for any purpose?

Attacker changes notAfter 2026 → 2036 without a new CA signature.
What happens?
→ **Signature verification fails.**

? QUICK CHECK



The issuer's signature authenticates the signed certificate fields and detects unauthorized modification.

CERTIFICATE PURPOSE & CONSTRAINTS

A Valid Certificate — But Valid for What?

X.509 v3 CERTIFICATE

KEY USAGE (KU)

What cryptographic operations?

Digital Signature
Key Encipherment
Key Agreement
Certificate Signing
CRL Signing

EXTENDED KEY USAGE (EKU)

For what application purpose?

TLS Server Auth.
TLS Client Auth.
Code Signing
Email Protection

BASIC CONSTRAINTS

May this certificate act as a CA?

CA = FALSE

→ End-entity cert

CA = TRUE

→ CA certificate

pathLenConstraint -> Limits subordinate CA Depth

REAL CERTIFICATE — mail.google.com

KU: Digital Signature

EKU: TLS Web Server Auth.

BC: **CA = FALSE**

? Can this certificate issue another certificate?

No — it is an end-entity certificate and is not authorized as a CA.

? THINK LIKE AN ENGINEER

Identity matches and usage is permitted — but is the certificate valid today?

INSIGHT

Cryptographic capability and certificate-authorized use are not the same thing.

X.509 extensions constrain how a certified key may be accepted and whether the certificate may act as a CA.

CERTIFICATE VALIDITY

A Certificate Is Not Valid Forever



VALIDITY FIELDS

notBefore
→ start of validity

notAfter
→ end of validity

Certificate Validity - QUICK CHECK

9 Aug 2026
→ Not yet valid

16 Sep 2026
→ Within validity

3 Nov 2026
→ Expired

IF THE KEY LEAKS…

Expires: 2 Nov 2026

Key compromised:
20 Sep 2026

Reject before 2 Nov?

? THINK LIKE AN ENGINEER

What if the private key is compromised before it expires?

INSIGHT

Expiration fails the time check, not the signature.

A certificate is time-valid only within its notBefore–notAfter interval—and may still become unacceptable before expiry.